API Security Risk Analysis Report

1. Introduction

This report presents a basic security analysis of a public API. The purpose of this task is to understand how APIs work and identify common security risks such as open access, data exposure, and lack of proper controls. The testing was done only on a public demo API in a safe and ethical manner.

2. API Tested

JSONPlaceholder API
https://jsonplaceholder.typicode.com

The following endpoints were tested:

- /posts
- /posts/1
- /users

3. Tools Used

- **Postman –** used to send API requests and view responses
- **Browser DevTools –** used to inspect network requests and headers
- **Insomnia –** considered as an alternative API testing tool

4. Methodology

The following steps were followed during the analysis:

1. Selected a public API for testing
2. Reviewed available endpoints
3. Sent requests using Postman
4. Observed the response data and behavior
5. Checked if authentication was required
6. Identified possible security risks
7. Suggested improvements

4. Findings

4.1 Open / Unauthenticated Endpoints

Severity: Medium

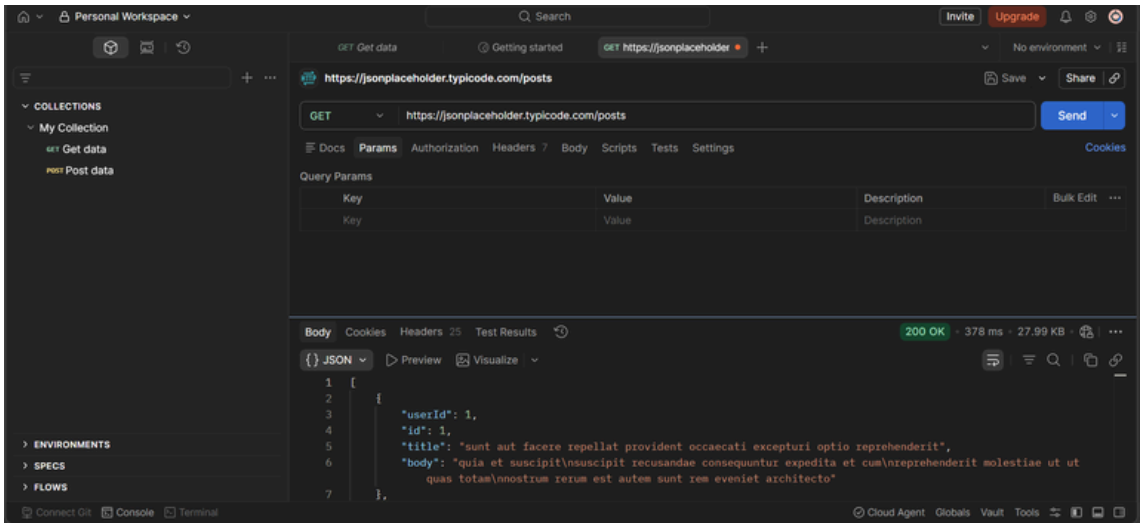
- The API allows access to data without any login or authentication.
- Anyone can open the API URL and view the data.

Business Impact:

- Unauthorized users can access information, which may lead to misuse or data leakage.

Suggestion:

- Require authentication (like login or API key) before giving access to data.



4.2 Excessive Data Exposure

Severity: Medium

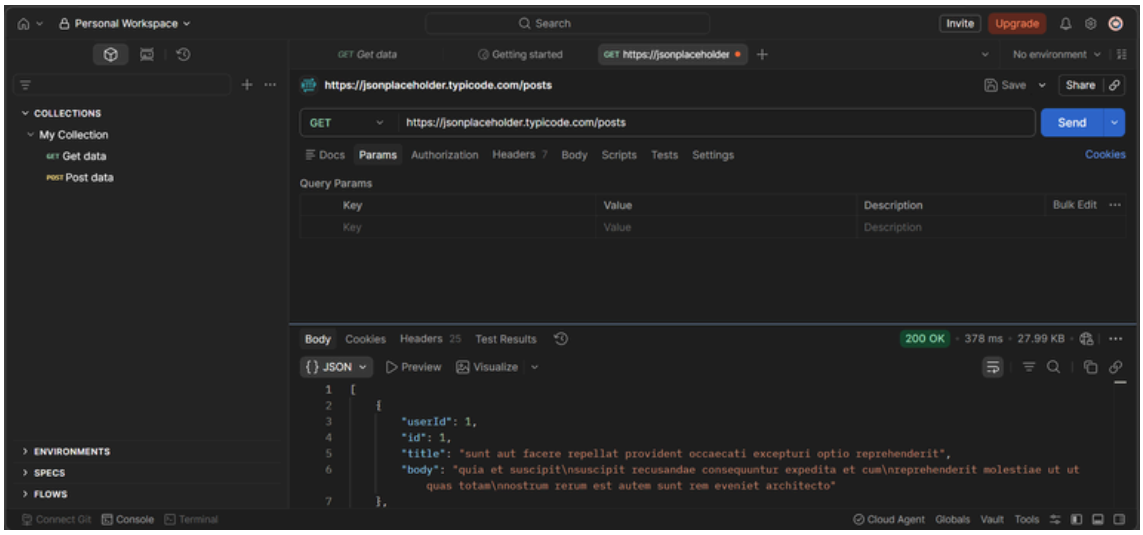
- The API returns full data including user IDs, titles, and content.
- Some of this information may not be necessary for all users.

Business Impact:

- Exposing more data than needed can increase the risk of information misuse.

Suggestion:

- Only return required data fields and hide unnecessary information.



4.3 Missing Authentication Mechanism

Severity: High

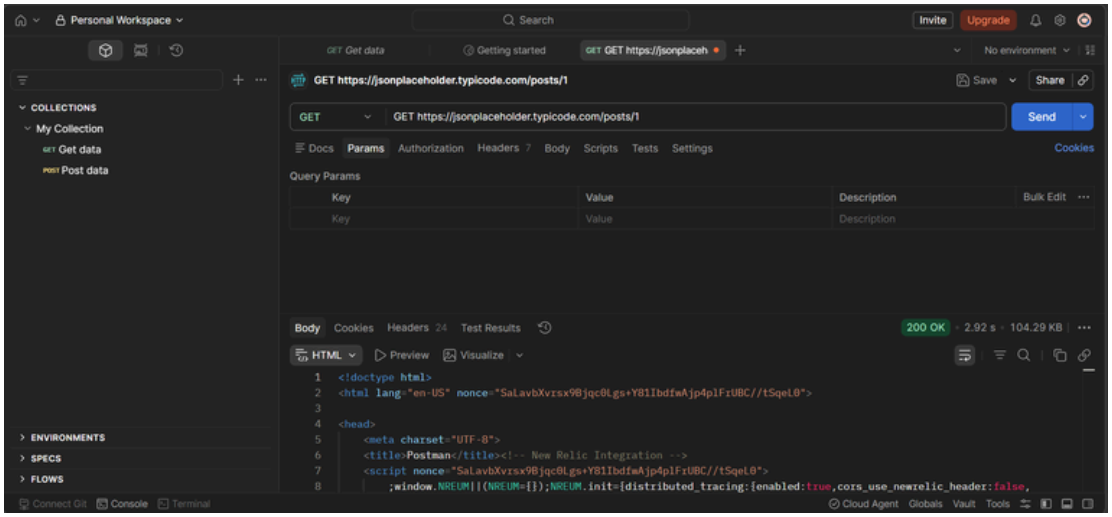
- The API does not use any authentication system such as tokens or login.
- There is no way to verify who is accessing the data.

Business Impact:

- This can allow unauthorized users to access and use the API freely.

Suggestion:

- Implement authentication methods such as API keys or tokens.



4.4 Missing Rate Limiting

Severity: Medium

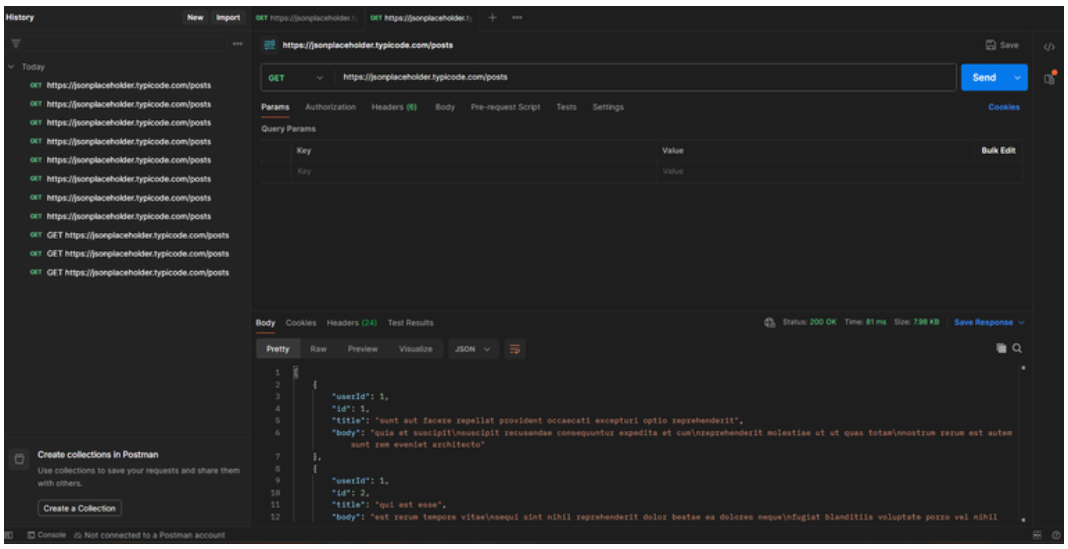
- The API allows unlimited requests without any restriction.

Business Impact:

- Attackers can send too many requests, which may slow down or crash the system.

Suggestion:

- Implement rate limiting to control the number of requests per user.



Multiple requests were sent without restriction

4.5 Input Validation Issues

Severity: Low

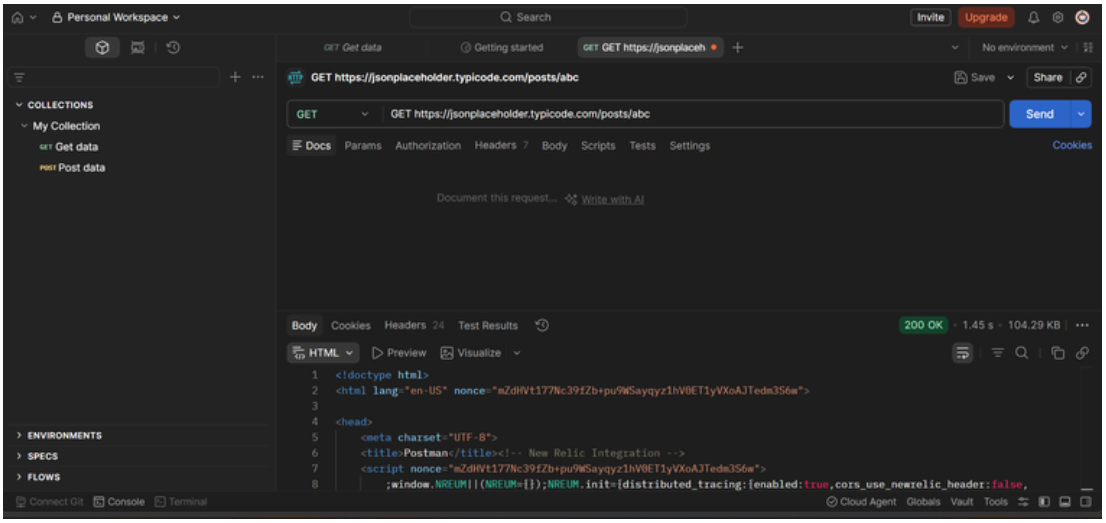
- The API does not strictly validate input values.
- Invalid inputs still return responses without proper error handling.

Business Impact:

- This may lead to unexpected behavior or misuse of the API.

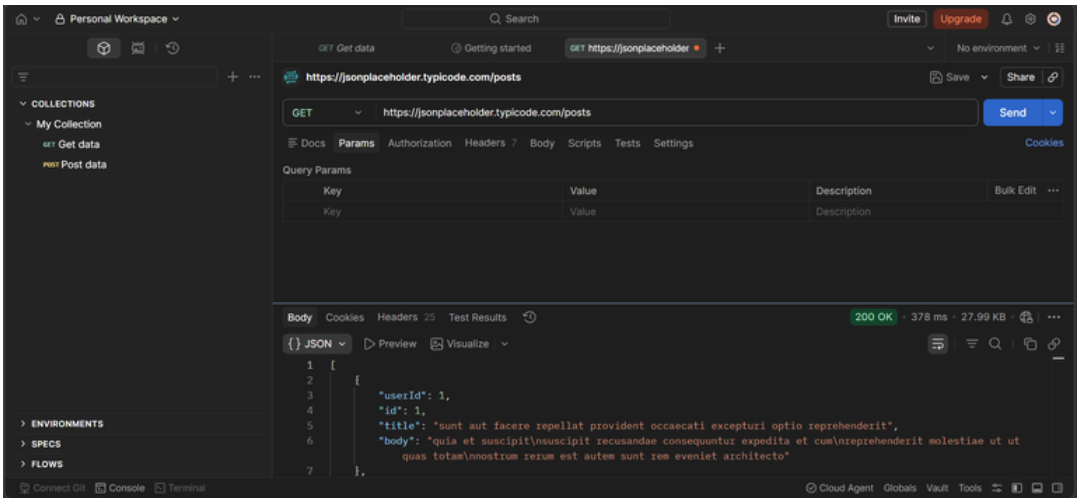
Suggestion:

- Validate all inputs and return proper error messages.

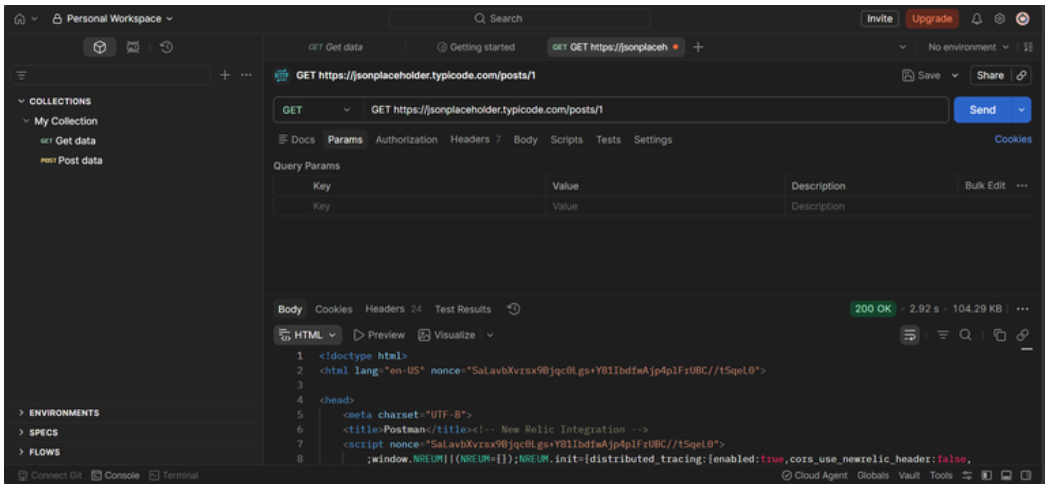


5. Screenshots Section

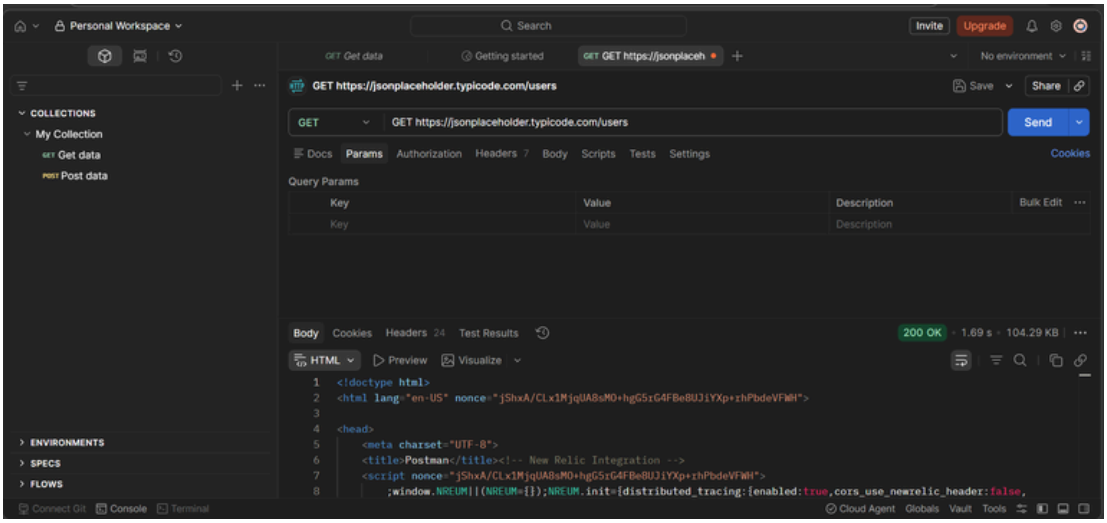
5.1 Postman GET /posts



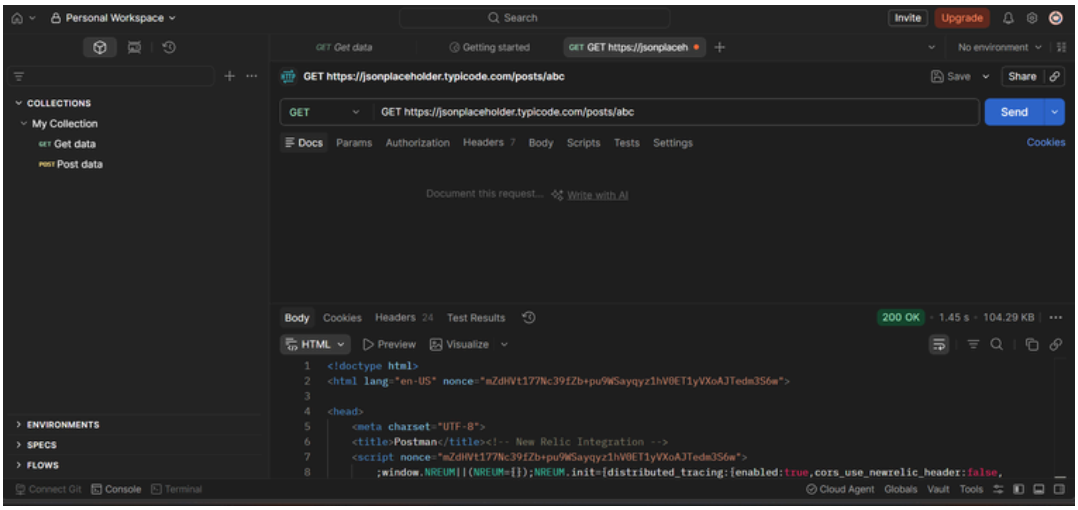
5.2 Postman GET /posts/1



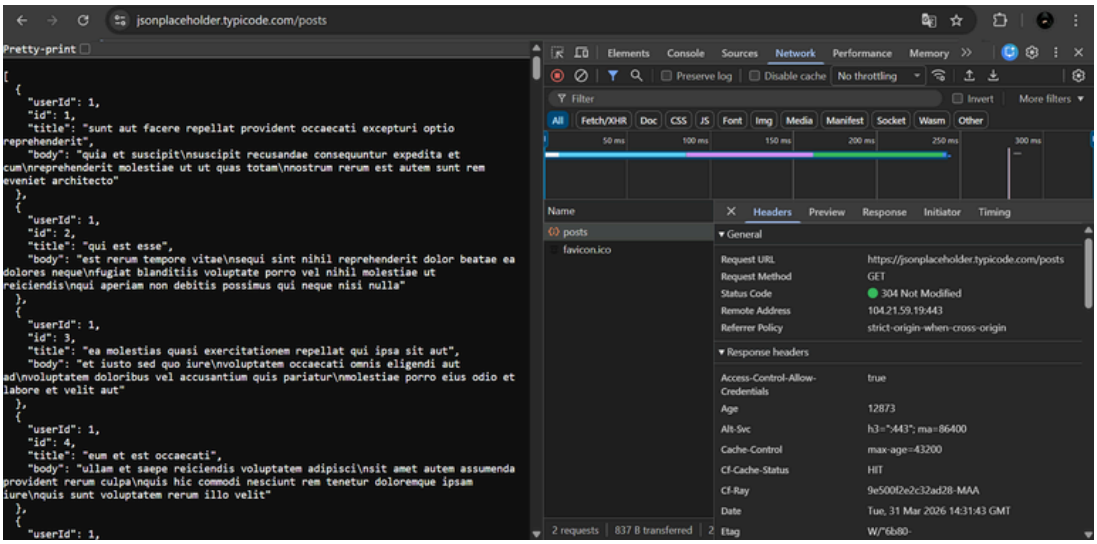
5.3 Postman GET /users



5.4 Invalid input test



5.5 DevTools Network tab



8. Conclusion

The API is useful for testing but lacks basic security controls such as authentication, authorization, and rate limiting. Even though this is a demo API, these issues can be serious in real-world applications. Proper security measures should be implemented to protect data and prevent misuse.